MedDataCloud Pvt. Ltd.

Risk Assessment Methodology

Contents

1. Document control
2. Purpose
3. Scope
4. Risk Assessment Approach
5. Asset identification
6. Threat identification
7. Vulnerability identification
8. Likelihood rating scale
9. Impact rating scale
10. Risk scoring matrix
11. Risk Acceptance Criteria
12. Risk treatment options
13. Risk assessment frequency
14. Review and Maintenance
15. Approval

1. Document Control:

Version	Date	Author	Description
1.0	11-03-2026	GRC analyst	Initial Version

2. Purpose:

This documentation defines the standard methodology used by the organization to identify, evaluate, and treat risks affecting the assets within the scope of the ISMS in accordance with ISO/IEC 27001:2022

3. Scope:

This methodology applies to all the assets identified and mentioned in asset inventory which includes information systems, people, data, and third-party services.

4. Risk Assessment Approach:

The organization follows an asset-based risk assessment methodology where risks are identified based on threats exploiting vulnerability associated with assets.

Risk formula:

Risk = Likelihood * Impact

5. Asset Identification:

The organization identifies and maintains inventory of all the assets that are within the scope of ISMS.

Assets include data, systems, people, services involved in the development, operation, and maintenance of the MedDataCloud platform.

Assets are identified through collaboration of relevant departments of the organizations.

Each identified asset is documented in asset inventory and assigned owner responsible for maintaining the asset.

Assets are categorized based on type and classified according to their sensitivity and business criticality.

6. Threat Identification:

Threat identification involves identifying potential actions that exploits the vulnerability and can cause harm to organizational assets. Threats may originate from internal or external sources and may be intentional, accidental or environmental.

The organization identifies threats by considering possible circumstances that could compromise the confidentiality, integrity and availability (CIA) of assets.

Organization identifies threats through following methods:

- Threat source analysis:
    - External actors
    - Internal actors
    - Environmental threats
    - Technological threats
- Threat Intelligence and Industry sources:
    - Threat intelligence feeds
    - Historical incident data
    - Industry reports

Identified threats are documented and mapped to relevant assets for further risk analysis.

7. Vulnerability Identification:

Vulnerability identification involves identifying the weakness in assets, process, systems that could be exploited by threats to cause harm to organization.

Vulnerability may exist in technology, people, process or physical infrastructure.
The organization uses following approaches to identify vulnerabilities:

- Technical security assessment:
    - Automted vulnerability scanning
    - Configuration assessment
    - Security testing

- Security audits and reviews:
    - Periodic security audits help to identify gaps in security controls and measures.
- Vulnerability intelligence sources:
    - Common vulnerabilities and exposures
    - National vulnerability database

8. Likelihood Rating scale:

Score	Likelihood	Description
1	Rare	Extremely unlikely
2	Unlikely	Could happen occasionally
3	Possible	Might occur sometimes
4	Likely	Expected to occur
5	Almost Certain	Happens frequently

9. Impact Rating scale:

Score	Impact Level	Description
1	Negligible	No operational impact
2	Minor	Limited disruption
3	Moderate	Noticeable operational disruption
4	Major	Significant service disruption
5	Severe	Critical business impact

10. Risk Scoring Method:

Risk = Likelihood * Impact

Likelihood→ Impact ↓	1	2	3	4	5
1	Low	Low	Low	Low	Medium
2	Low	Low	Medium	Medium	Medium
3	Low	Medium	Medium	High	High
4	Medium	Medium	High	High	Critical
5	Medium	High	High	Critical	Critical

- Classification:

Score	**Risk Level**
1-5	Low
6-10	Medium
11-15	High
16-25	Critical

11. Risk Acceptance Criteria:

Organization has defined risk acceptance criteria as below:

Risk Level	**Actions**
Low	Accept
Medium	Monitor
High	Treat
Critical	Immediate treatment

12. Risk treatment options:

ISO defines 4 risk treatment strategies:

Strategy	**Meaning**
Mitigate	Implement controls
Avoid	Stop risky activity
Transfer	Use insurance or third party
Accept	Accept the risk

13. Review and Maintenance:

The ISMS scope shall be reviewed periodically to ensure it remains aligned with organizational objectives and regulatory requirements.

Scope review will occur under following conditions:

- Significant changes in business operations
- New systems or infrastructure introduced
- Changes in regulatory requirements
- Major security incidents or risk assessments

The ISMS scope should be reviewed at least annually as a part of management review process.

14. Approval:

This ISMS scope document has been reviewed and approved by organizational leadership responsible for governance of ISMS.

Role	Name	Approval
Chief Executive Officer	—	Approved